

Data Protection Training Notes

Quick Summary



DO:

- Ask yourself: Is this data necessary for what we are trying to do?
- Use clear, simple language when asking for consent
- Protect data with appropriate security
- Tell people openly what you do with their data
- Respect people's rights over their own information
- Tell the Legal team immediately if something goes wrong



DON'T:

- Collect data "just in case" you might need it
- Assume silence means consent
- Leave data lying around unprotected
- Use data for purposes different from why you collected it without asking first
- Keep data longer than necessary

1. What is Personal Data?

Personal data is:

- Any information about a living individual AND
- You can identify the individual from it AND
- It exists in a form that can be processed

Common examples:

- Name
- Credit card details
- Email address
- Mobile phone number
- Personal photos
- ID number

2. Six Key Principles for Handling Personal Data

You must follow these principles when you handle personal data:

Principle 1: Data Collection

What you must do:

Consider the below...	Rule
Why are you collecting this data?	The purpose must be lawful and directly related to what you are trying to do

How much data do you need?	Collect only what is necessary, adequate, and not excessive
How should you collect it?	Use methods that are lawful, fair, and transparent

Example: Your marketing team runs a lucky draw and needs to contact winners

- **Acceptable:** Collect names and phone numbers only
- **Why:** The purpose (notifying winners) is lawful and directly related. You only collect what you need.
- **Unacceptable:** Collecting customers' blood group information
- **Why:** Blood group information is not necessary to run a draw or contact winners

Principle 2: Accuracy and Data Retention

What you must do:

- Keep personal data accurate
- Delete data when you no longer need it for its original purpose

What happens if you don't:

- Maximum penalty: **HK\$10,000**

Example:

After a student graduates from school, the school should delete information like emergency contacts, previous addresses, and other sensitive data that is no longer needed—unless the student has given further consent to keep it.

Principle 3: Using Data for New Purposes

What you must do: You can only use personal data for the purpose it was originally collected for. If you want to use it for something different, you must get permission (i.e. consent).

What is “valid consent”?

Requirements	What it means
Freely given	The person chooses freely, with no pressure or conditions
Specific and informed	Explain clearly (in simple language they understand) what you'll do with their data
Unambiguous	Get a clear "yes", not silence. Silence is not consent. Pre-ticked boxes are not consent.
Explicit	They must make a clear statement, like checking a box or signing

Example:

Before your company sends marketing emails to staff members, you must:

1. Explain what the marketing campaign is about
2. Ask staff to check a box to show they consent to receiving marketing emails
3. Only send marketing emails to those who have consented

Why this matters: Staff might have given their contact information for employment purposes only, not marketing.

Principle 4: Data Security

What you must do: Take appropriate security measures to protect personal data

What "appropriate" means depends on:

- What type of data you are protecting (general vs. sensitive)
- How easy it would be for someone to misuse it
- What could go wrong if it was compromised

Security measures you should take:

Internal

- Access controls (only relevant staff can see the data)
- Security software (antivirus, firewalls)
- Password-protected files
- Encrypted communications

External

- Contracts with third-party service providers that outline their data protection responsibilities

Practical tips:

Situation	What to do
Sending emails with personal data	Double-check the email address before you send. Don't send to the wrong person.
Sending bulk emails to multiple people	Use the "bcc" field so everyone's email address stays private
Using cloud services	Have a contract in place with the provider that protects data

How to handle a data incident if you suspect personal data has been lost, stolen, or exposed:

1. **Tell the Legal team immediately:** don't wait or try to fix it yourself
2. **Use this wording:** "Potential data incident"
3. **Don't use these terms:** "data breach", "data leak", "cybersecurity incident" or similar

Why the specific wording? Legal needs to assess the situation properly, and certain terms have specific legal meanings.

Principle 5: Openness and Transparency

What you must do:

- Be open about what data you collect and how you use it
 - Make your data practices clear and accessible
 - Don't hide what you are doing with the personal data collected
-

Principle 6: Data Subject Rights

People have the following rights when it comes to their personal data:

Data subject right	Does this right exist in HK?	Does this right exist in UK?
Access their personal data and know what you hold	✓	✓
Correct data that is inaccurate	✓	✓
Erase their data in certain situations	X	✓
Object to how their data is being used	X	✓
Request portability of their data (i.e. getting it in a format they can move elsewhere)	X	✓
Restrict or suppress their data in certain circumstances (i.e. limit the way we use their data)	X	✓

What you must do: Respect these rights when people ask to exercise them

When to comply with a data subject request:

- **HK:** within 40 days
 - **UK:** within 1 month
-

3. Penalties for Non-Compliance

The consequences for breaching data protection laws vary depending on the violation:

- **Minor violations** may result in smaller fines
- **Major violations** can result in significant financial penalties
- **Penalties escalate** for repeated or serious breaches
- Fines in **HK** can reach **HK\$50,000 + 2 years imprisonment**, while fines in **UK** can reach up to **£17.5 million** or **4% of global turnover** depending on the offence

Not following the rules doesn't just cost money, it damages trust and your organization's reputation.

4. Key Roles in Data Protection

Data Subject

Definition: The living person whose personal data is being handled

Examples:

- Customers
- Employees
- Merchant contacts

Data Controller

Definition: The person or organization that decides **what** personal data is collected and **how** it will be used

Example: Your company is the data controller for customer personal data

What a data controller must do:

- Follow all data protection rules (including but not limited to the six data protection principles above)
- Comply with data subject requests
- Enter into written contracts with anyone who processes data on your behalf, explaining what they must do

Data Processor

Definition: A person or organization that processes personal data **on behalf of** the data controller. They don't decide how the data is used, they just handle it according to the **data controller's instructions**.

Examples:

- Cloud service providers
- IT vendors
- Third-party service providers

What a data processor must do:

- Process data only as instructed by the data controller
- Implement strong technical and organizational security measures
- Tell the data controller immediately if there is a suspected data incident
- Comply with written agreements with the data controller that outline these responsibilities

Questions? Contact Us

If you are unsure about data protection requirements, contact the Legal - Corporate Compliance team.